

Laboratório de Banco de Dados

Profa. Msc. Esteic Janaina
Santos Batista

Módulo 4 - Controle de Concorrência e Administração de Banco de Dados

**Unidade 1 - Segurança e Autorização em Banco de
Dados**



UFMS
AGEAD

Agência de Educação
Digital e a Distância

Conceito de Segurança em Banco de Dados

- Segurança em banco de dados envolve a aplicação de políticas e mecanismos que garantem a proteção dos dados contra acessos não autorizados.
- Utiliza mecanismos de autorização para controlar quem pode acessar ou manipular informações específicas no banco de dados.
- Exemplo: sistema financeiro.

Mecanismos de Autorização

- No contexto de segurança em bancos de dados, privilégios são permissões que podem ser concedidas a usuários para realizar operações específicas em um banco de dados.
- Esses privilégios garantem o controle sobre quem pode acessar e modificar os dados ou os esquemas.
- Permissões são concedidas para ações específicas: leitura (SELECT), inserção (INSERT), atualização (UPDATE) e exclusão (DELETE).

Mecanismos de Autorização

- A manipulação de esquemas em SQL envolve permissões que permitem aos usuários modificar a estrutura do banco de dados, criando ou alterando objetos, como tabelas, índices, visões, etc.
 - CREATE: Permissão para criar novos objetos no banco de dados, como tabelas, índices ou visões.
 - ALTER: Permissão para modificar a estrutura de objetos existentes, como adicionar ou remover colunas em uma tabela.

Mecanismos de Autorização



- DROP: Permissão para excluir objetos do banco de dados, como tabelas ou visões.

Comando GRANT

- O comando **GRANT** em SQL é usado para conceder privilégios a usuários ou papéis (roles). A sintaxe básica é a seguinte:

GRANT <lista de privilégios> ON <nome da tabela ou view> TO
<usuário ou role>;

Exemplos de uso do comando GRANT

- Concedendo o privilégio de leitura a um usuário:

```
GRANT SELECT ON tabela_clientes TO usuario_leitura;
```

- Neste exemplo, o usuário usuario_leitura poderá realizar consultas (SELECT) na tabela tabela_clientes.

Exemplos de uso do comando GRANT

- Concedendo o privilégio de atualização em colunas específicas:

```
GRANT UPDATE (preco) ON tabela_produtos TO  
usuario_atualizador;
```

- Aqui, o privilégio UPDATE é concedido apenas para a coluna preco na tabela tabela_produtos.
- O usuário usuario_atualizador poderá modificar os preços, mas não terá permissão para atualizar outras colunas.

Exemplos de uso do comando GRANT

- Para conceder privilégios de SELECT e UPDATE ao usuário na tabela tabela_vendas, você pode usar o comando GRANT da seguinte forma:

```
GRANT SELECT, UPDATE ON tabela_vendas TO  
usuario_completo;
```

Exemplos de uso do comando GRANT

- Concedendo todos os privilégios disponíveis:

```
GRANT ALL PRIVILEGES ON tabela_vendas TO  
usuario_completo;
```

- O usuário usuario_completo receberá todos os privilégios (como SELECT, INSERT, UPDATE, DELETE) sobre a tabela tabela_vendas.

Comando REVOKE

- O comando **REVOKE** é usado para remover privilégios que foram concedidos anteriormente a um usuário ou papel. A sintaxe básica é:

```
REVOKE <lista de privilégios> ON <nome da tabela ou view>  
FROM <usuário ou role>;
```

Exemplos de uso do comando REVOKE

- Removendo o privilégio de leitura de um usuário:

```
REVOKE SELECT ON tabela_clientes FROM usuario_leitura;
```

- Este comando revoga o privilégio SELECT do usuário usuario_leitura na tabela tabela_clientes, impedindo-o de realizar consultas na tabela.

Exemplos de uso do comando REVOKE

- Revogando todos os privilégios concedidos:

```
REVOKE ALL PRIVILEGES ON tabela_vendas FROM  
usuario_completo;
```

- Neste exemplo, o comando remove todos os privilégios concedidos anteriormente ao usuário usuario_completo na tabela tabela_vendas.

Implicações do comando REVOKE

- Ao revogar privilégios, especialmente quando se usa o comando REVOKE ALL PRIVILEGES, os usuários ou papéis afetados perdem o acesso para executar ações específicas nos objetos do banco de dados.
- Além disso, quando um privilégio é revogado de um usuário que o concedeu a outro, todos os privilégios concedidos por esse usuário também são revogados (revogação em cascata).

Roles (papéis) no controle de acesso

- Roles (papéis) no controle de acesso são uma forma de simplificar e organizar a administração de permissões em um banco de dados, especialmente em cenários com muitos usuários e diferentes níveis de acesso.
- Em vez de conceder privilégios individualmente a cada usuário, os privilégios podem ser agrupados em um "*role*" (papel), e então o *role* é atribuído aos usuários.
- Isso facilita a administração, pois os privilégios podem ser gerenciados centralmente através dos roles.

Vantagens de usar *roles*

- Facilitam a administração de permissões: ao invés de configurar privilégios para cada usuário separadamente, os privilégios podem ser atribuídos a um *role*, e o *role* é então concedido aos usuários.
- Escalabilidade: permitem gerenciar permissões de forma eficiente em ambientes com muitos usuários.
- Segurança centralizada: permissões são gerenciadas em um único lugar, reduzindo o risco de configurações de acesso incorretas.

Criação e concessão de *roles*

Criando um *role*

- O comando **CREATE ROLE** é usado para criar um novo *role* no banco de dados:

```
CREATE ROLE instrutor;
```

Criação e concessão de *roles*

Concedendo privilégios a um *role*

- Este comando concede ao role instrutor o privilégio de leitura (SELECT) na tabela tabela. Qualquer usuário associado ao role instrutor terá essa permissão.

```
GRANT SELECT ON tabela TO instrutor;
```

Criação e concessão de *roles*

Associando um *role* a um usuário

- Depois de configurar os privilégios do *role*, ele pode ser associado a um usuário com o comando GRANT.

GRANT instrutor TO usuario;

- Esse comando concede ao usuário todos os privilégios do *role* instrutor. A partir desse momento, o usuário terá as mesmas permissões configuradas no *role*.

Exemplos de roles

```
CREATE ROLE DBA;
```

```
GRANT ALL PRIVILEGES ON banco_de_dados TO DBA;
```

```
GRANT DBA TO admin;
```

Exemplos de roles

CREATE ROLE Estagiario;

GRANT SELECT ON clientes TO Estagiario;

GRANT Estagiario TO Joao;

Autorização sobre *views*

- Vantagens de usar *views* para controle de acesso
 - Simplificação das consultas
 - Manutenção da segurança
 - Controle granular de acesso aos dados

Autorização sobre views

- Vamos criar uma *view* que mostra apenas os dados dos funcionários que são gerentes.

```
CREATE VIEW gerentes AS
```

```
SELECT nome, salario
```

```
FROM funcionarios
```

```
WHERE cargo = 'Gerente';
```


Autorização sobre views

- Concedendo privilégios em *views*

GRANT SELECT ON gerentes TO usuario;

Autorização em nível de linha

- É um mecanismo de controle de acesso que permite definir quais linhas (ou tuplas) de uma tabela um usuário pode visualizar ou manipular.
- Diferente dos privilégios tradicionais, que aplicam permissões à tabela inteira ou a colunas específicas, a autorização em nível de linha oferece uma maneira de controlar o acesso com maior precisão.

Autorização em nível de linha

```
CREATE VIEW vendas_vendedor1 AS
```

```
SELECT * FROM registros_vendas WHERE vendedor_id = 1;
```

```
GRANT SELECT ON vendas_vendedor1 TO vendedor1_user;
```

Práticas de segurança recomendadas

- Princípio do mínimo privilégio: conceder aos usuários apenas os privilégios estritamente necessários para a execução de suas tarefas.
- Auditoria e registro de acessos: auditoria é o processo de monitorar e registrar atividades realizadas no banco de dados, como operações de leitura, escrita, atualização e exclusão. As informações registradas incluem o usuário que realizou a operação, o momento em que ocorreu e o tipo de ação executada.

Referências



SILBERSCHATZ, Abraham; KORTH, Henry F.; SUDARSHAN, S. **Sistema de Banco de Dados**. Rio de Janeiro: GEN LTC, 2020. ISBN 9788595157552. **Disponível na Biblioteca Digital da UFMS.** Trecho a ser lido: **Capítulo 4. Seção 4.7.**

Licenciamento



Respeitadas as formas de citação formal de autores de acordo com as normas da ABNT NBR 6023 (2018), a não ser que esteja indicado de outra forma, todo material desta apresentação está licenciado sob uma [Licença Creative Commons - Atribuição 4.0 Internacional](#).

